

Penetration Testing Assessment

OWASP Broken Web Applications / NetLab Sandbox

A gray-box assessment of the deliberately vulnerable web application environment, conducted from the simulated WAN segment with validation of critical server-side injection flaws.

PREPARED BY

Justin Martin

COURSE

IT460

ASSESSMENT DATE

August 23, 2026

ASSESSMENT WINDOW

17:08–17:40 EDT (approximate)

CLASSIFICATION

Educational / Controlled Lab

Authorization All activity described in this report was performed inside the assigned NetLab Cyber Range against the intentionally vulnerable OWASP BWA host. No public Internet targets were tested.

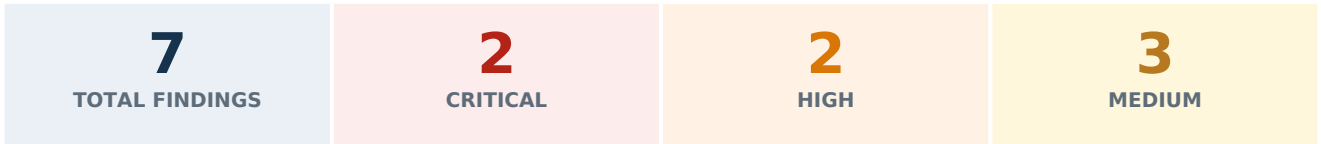
DECISION BRIEF

Executive Summary

The assessment confirmed that the OWASP Broken Web Applications host is critically exposed to server-side injection. Two independent attack paths were validated: SQL injection disclosed 24 account records and plaintext passwords, and operating-system command injection executed commands as the Apache service account (www-data). Either condition can enable rapid compromise; together they demonstrate ineffective input handling and inadequate separation between the application and its host operating system.

The host also exposed a DVWA database reset function without an authenticated administrative session, numerous unsupported software components, legacy SMB services with message signing disabled, verbose database errors, directory listings, unsafe HTTP methods, and missing browser security controls. The environment is intentionally vulnerable for training, but the same conditions in production would warrant immediate containment and rebuild.

Risk at a glance



Immediate priorities

- Remove the affected web application from any untrusted network until injection flaws are corrected and retested.
- Invalidate exposed credentials, require password changes, and move password storage to a modern salted adaptive hash.
- Rebuild the host on supported software; do not attempt to patch the legacy stack in place as a long-term solution.
- Restrict administrative/setup functions and legacy services to trusted management networks only.

Overall risk CRITICAL. Exploitation required only normal web access and crafted input. No authentication, special privileges, or user interaction was required for the two principal attack paths.

REPORT MAP

Contents

01	Engagement Overview	Scope, constraints, timing, and rules of engagement
02	Environment & Methodology	Network path and repeatable testing process
03	Summary of Findings	Severity-ranked results and attack narrative
04	Detailed Findings	Evidence, impact, reproduction, and remediation
05	Remediation Roadmap	Prioritized actions and validation plan
06	Conclusion & Reflection	Assessment conclusion and professional learning
A	Appendix	Ports, commands, evidence index, and references

Assessment basis

This report is based on direct evidence collected from the assigned cyber range: network configuration, Nmap output, web fingerprinting, Nikto results, and manual validation in Mutillidae and DVWA. Automated findings were treated as leads and were not elevated beyond the evidence shown.

CVSS note Scores in this report are analyst estimates using CVSS v3.1 concepts. They communicate relative urgency for the lab and are not vendor-assigned scores.

01 / ENGAGEMENT

Engagement Overview

Objective	Identify and validate exploitable weaknesses on the OWASP BWA host and provide actionable remediation guidance.
Assessment type	Gray-box penetration test with limited architecture knowledge and no application credentials at the start.
Source	Kali Linux, 192.168.9.2/24, simulated WAN segment.
Target	OWASP Broken Web Applications, 192.168.68.12/24, DMZ segment.
Timing	August 23, 2026; approximately 17:08-17:40 EDT.
Authorization	Assigned NetLab Cyber Range only; controlled educational environment.

Scope and constraints

IN SCOPE	OUT OF SCOPE
- OWASP BWA host (192.168.68.12) - Hosted HTTP applications - DMZ host/service discovery - Safe validation of web flaws	- Public Internet - pfSense administration - Protected LAN hosts - DoS, persistence, destructive changes, or data deletion

Testing was designed to demonstrate risk while minimizing impact. Only the intentionally vulnerable target was actively assessed. Database reset was used solely within DVWA’s purpose-built setup workflow; no unrelated systems or user data were altered.

02 / ENVIRONMENT

Environment and Network Path

Assessed NetLab Path and Scope Boundary

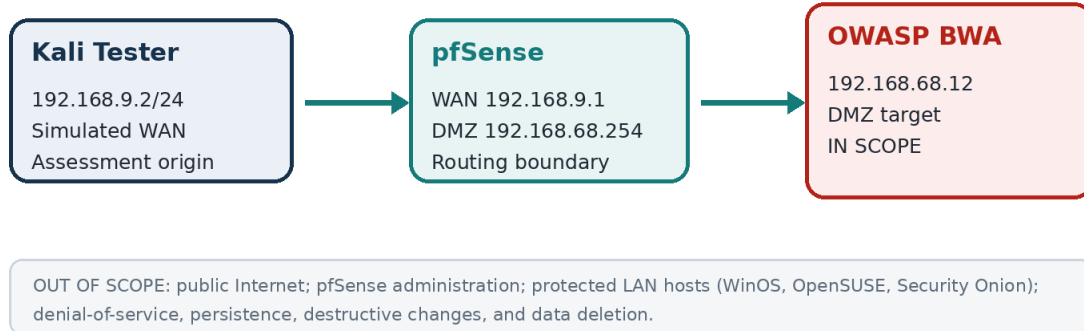


Figure 2.1 — Simplified assessment path and scope boundary.

The Kali host had a single IPv4 address on eth0 (192.168.9.2/24) and used 192.168.9.1 as its default gateway. The target resided two routed hops away in the 192.168.68.0/24 DMZ. The protected 192.168.0.0/24 LAN was intentionally excluded from active testing.

```

root@kali:~# mkdir -p /root/it460-final/scans
root@kali:~# mkdir -p /root/it460-final/evidence
root@kali:~# script -a /root/it460-final/evidence/terminal-session.txt
Script started, file is /root/it460-final/evidence/terminal-session.txt
root@kali:~# ip -br addr
lo                UNKNOWN      127.0.0.1/8  ::1/128
eth0              UP          192.168.9.2/24  fe80::250:56ff:fe99:2509/64
eth1              UP
docker0          DOWN       172.17.0.1/16
root@kali:~# ip route
default via 192.168.9.1 dev eth0 proto static metric 100
172.17.0.0/16 dev docker0 proto kernel scope link src 172.17.0.1 linkdown
192.168.9.0/24 dev eth0 proto kernel scope link src 192.168.9.2 metric 100
root@kali:~#
  
```

Figure 2.2 — Kali interface and routing context captured before testing.

02 / PROCESS

Testing Methodology

1	Prepare	Created a dedicated evidence directory and terminal transcript; confirmed source addressing and routing.
2	Discover	Confirmed the DMZ target and used host discovery cautiously across the authorized range.
3	Enumerate	Ran a full TCP port scan, then service/version detection and safe default scripts.
4	Fingerprint	Used WhatWeb and Nikto to identify the web stack, exposed paths, headers, and configuration weaknesses.
5	Validate	Manually reproduced SQL injection and command injection in Mutillidae and tested DVWA setup access.
6	Analyze	Correlated manual proof with scan evidence, rated findings, and produced prioritized remediation.

Core tools

- Nmap 7.80 — TCP discovery, service/version detection, OS inference, and safe NSE checks.
- WhatWeb — web technology fingerprinting and exposed metadata review.
- Nikto 2.1.6 — web server misconfiguration and outdated-component checks.
- Firefox — manual application validation and evidence capture.

Evidence standard A finding was marked Validated only when the behavior was reproduced manually or directly supported by deterministic scan output. Scanner-only observations remain qualified in the narrative.

03 / RESULTS

Summary of Findings

ID	Finding	Severity	CVSS*	Status
F-01	SQL Injection and Plaintext Credential Disclosure	Critical	9.8	Validated
F-02	Operating-System Command Injection	Critical	9.8	Validated
F-03	Unauthenticated DVWA Database Reset Function	High	8.1	Validated
F-04	Unsupported and Severely Outdated Components	High	8.1	Observed
F-05	Web Server Security Misconfiguration	Medium	6.5	Observed
F-06	Verbose Error and Internal Path Disclosure	Medium	5.3	Validated
F-07	SMB Message Signing Disabled	Medium	5.9	Observed

* Estimated CVSS v3.1 base score used for prioritization in this controlled lab.

```

root@kali:~# echo "Justin Martin | IT460 Final Project | Full Port Scan Summary"
Justin Martin | IT460 Final Project | Full Port Scan Summary
root@kali:~# grep -E '^(PORT|[0-9]+)/tcp|Nmap done)' /root/it460-final/scans/owaspbwa-full.nmap
PORT      STATE SERVICE      REASON
22/tcp    open  ssh          syn-ack ttl 63
80/tcp    open  http         syn-ack ttl 63
139/tcp   open  netbios-ssn  syn-ack ttl 63
143/tcp   open  imap         syn-ack ttl 63
443/tcp   open  https        syn-ack ttl 63
445/tcp   open  microsoft-ds syn-ack ttl 63
5001/tcp   open  complex-link syn-ack ttl 63
8080/tcp   open  http-proxy   syn-ack ttl 63
8081/tcp   open  blackice-icecap syn-ack ttl 63
root@kali:~#

```

Figure 3.1 — Full TCP scan summary showing nine open services.

03 / ATTACK PATH

Validated Attack Narrative

The assessment established a short, repeatable path from network access to application and host compromise. The attack did not depend on phishing, credentials, or endpoint access.

01	Reach target	Kali reached 192.168.68.12 through pfSense from the simulated WAN.
02	Enumerate	Nine TCP services were exposed, including multiple web stacks and legacy SMB.
03	Fingerprint	Apache 2.2.14, PHP 5.3.2, OpenSSL 0.9.8k, Jetty, and Tomcat were identified.
04	Inject	SQL injection returned 24 account records; command injection ran as www-data.
05	Escalate access	Disclosed admin credentials successfully authenticated to Mutillidae.
		Business consequence An external attacker with only HTTP reachability could obtain reusable credentials and execute commands in the web server context. Those capabilities create credible paths to data theft, application tampering, service disruption, and lateral movement.

04 / DETAILED FINDINGS

F-01 SQL Injection and Plaintext Credential Disclosure

SEVERITY Critical	CVSS 9.8	STATUS Validated	ASSET OWASP BWA / 192.168.68.12
-----------------------------	--------------------	----------------------------	---

Description

The Mutillidae account-details function concatenated untrusted input into a SQL query. Supplying a tautology caused the application to return every matching record instead of a single account. The response exposed 24 account records with plaintext passwords, including the administrative account.

Proof of concept

Navigate to OWASP 2013 → A1 Injection (SQL) → SQLi - Extract Data → User Info. Enter the payload below in the Name field, enter test as the password, and select View Account Details.

	Payload ' OR 1=1 #
--	---------------------------

Name

Password

[View Account Details](#)

Dont have an account? [Please register here](#)

Results for "' OR 1=1 #".24 records found.

```

Username=admin
Password=admin
Signature=g0t r00t?

Username=adrian
Password=somepassword
Signature=Zombie Films Rock!

Username=john
Password=monkey
Signature=I like the smell of confunk

Username=jeremy
Password=password
Signature=d1373 1337 speak

Username=bryce
Password=password
Signature=I Love SANS

Username=samurai
Password=samurai
Signature=Carving fools
  
```

Figure F-01.1 — Tautology-based SQL injection returned 24 account records and plaintext passwords.

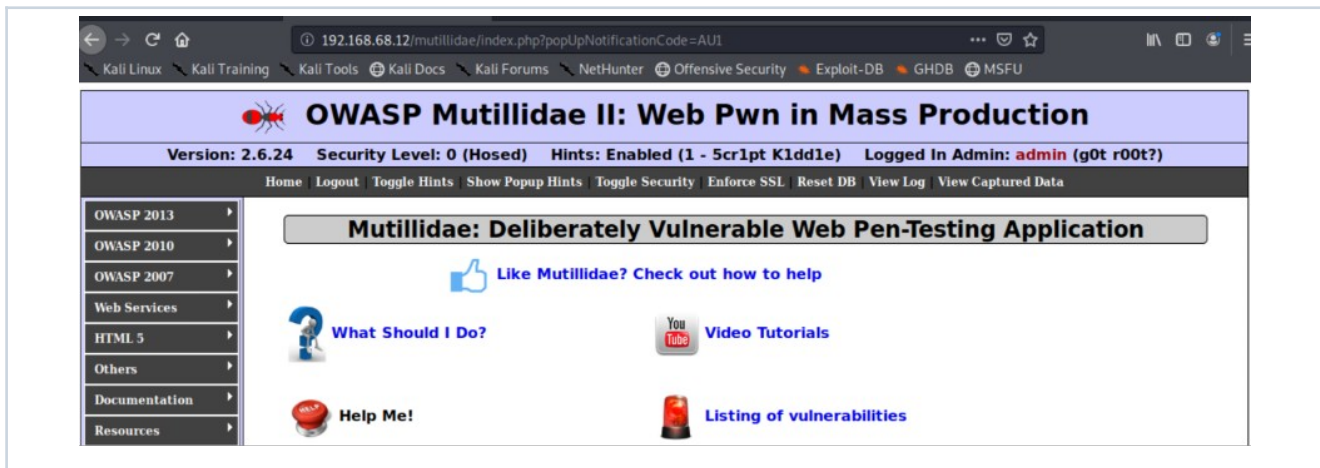


Figure F-01.2 — The disclosed admin/admin credential successfully authenticated to Mutillidae.

Impact

The flaw permits bulk disclosure of application credentials and immediate account takeover. Because passwords were returned in plaintext, any credential reuse could extend the impact beyond the application. Administrative access was confirmed using the exposed account.

Recommended remediation

Priority	Action
1	Replace dynamic SQL concatenation with parameterized queries or prepared statements for every data access path.
2	Store passwords only as salted adaptive hashes such as Argon2id, bcrypt, scrypt, or PBKDF2; never return password values to the client.
3	Invalidate and rotate all exposed credentials, enforce unique passwords, and require MFA for administrative accounts.
4	Apply least-privilege database permissions and alert on tautologies, comments, and abnormal multi-record responses.
5	Retest all account lookup, authentication, and search functions with automated and manual injection cases.

04 / DETAILED FINDINGS

F-02 Operating-System Command Injection

SEVERITY Critical	CVSS 9.8	STATUS Validated	ASSET OWASP BWA / 192.168.68.12
------------------------------------	---------------------------	-----------------------------------	--

Description

The Mutillidae DNS lookup function passed user-controlled input to an operating-system shell. Shell metacharacters appended additional commands to the intended lookup. The server executed whoami and id and returned their output in the HTTP response.

Proof of concept

Navigate to OWASP 2013 → A1 Injection (Other) → Command Injection → DNS Lookup. Submit the following value as the hostname/IP:

Payload	127.0.0.1 && whoami && id
----------------	---------------------------

The screenshot shows the Mutillidae DNS Lookup tool interface. At the top, there is a text input field labeled "Hostname/IP" containing the value "127.0.0.1 && whoami && id". Below the input field is a button labeled "Lookup DNS". The results are displayed in a box titled "Results for 127.0.0.1 && whoami && id". The results show the server's IP address (192.168.68.254) and the output of the whoami and id commands, which is "www-data" and "uid=33(www-data) gid=33(www-data) groups=33(www-data)".

Figure F-02.1 — Server-side execution returned www-data and uid=33(www-data).

Impact

An unauthenticated attacker can execute arbitrary commands with the privileges of the Apache service account. This can expose application secrets, permit file modification, establish a foothold, and support lateral movement. The demonstrated user was not root, but web-service access is sufficient for substantial application and data compromise.

Recommended remediation

Priority	Action
1	Remove shell execution from the lookup workflow and call a purpose-built DNS resolver library instead.
2	Apply strict allowlisting for valid hostnames and IP addresses before any backend operation.
3	Run the web service with minimal filesystem and network privileges and confine it with mandatory access controls.
4	Treat escaping as defense in depth only; do not rely on escaping to make shell construction safe.
5	Review logs for command separators and unexpected child processes, then retest with common shell metacharacters.

04 / DETAILED FINDINGS

F-03 Unauthenticated DVWA Database Reset Function

SEVERITY High	CVSS 8.1	STATUS Validated	ASSET OWASP BWA / 192.168.68.12
-------------------------	--------------------	----------------------------	---

Description

The DVWA setup page was reachable without an authenticated application session. Although normal DVWA login attempts failed, the setup workflow allowed the database to be created or reset and reported successful recreation of the users and guestbook tables.

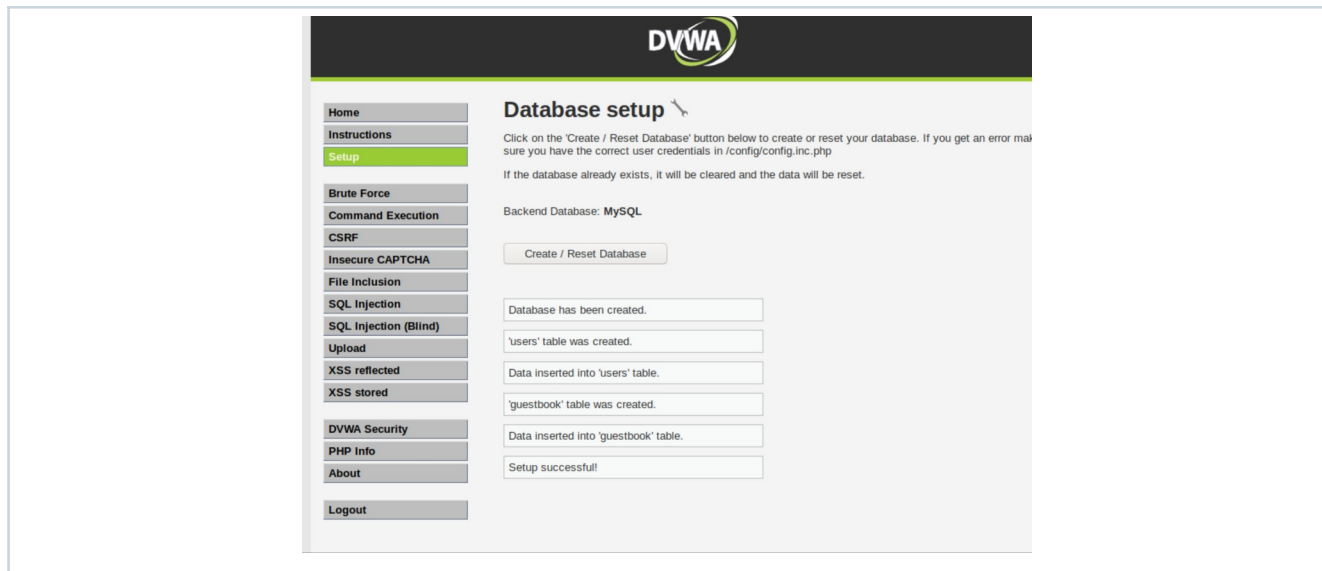


Figure F-03.1 — DVWA setup reported successful database and table recreation.

Impact

An exposed reset function can destroy application state, restore default accounts, and interrupt service. In this lab the action affected only the deliberately vulnerable DVWA database; in a production design, an equivalent unauthenticated maintenance endpoint would create serious integrity and availability risk.

Recommended remediation

Priority	Action
1	Require an authenticated administrative session and explicit authorization for all setup and reset actions.
2	Remove installation and setup scripts after deployment or restrict them to a dedicated management network.
3	Require CSRF protection, reauthentication, and a clear confirmation step for destructive administrative actions.
4	Log every reset attempt and alert when the function is invoked outside an approved maintenance window.

04 / DETAILED FINDINGS

F-04 Unsupported and Severely Outdated Components

SEVERITY High	CVSS 8.1	STATUS Observed	ASSET OWASP BWA / 192.168.68.12
-------------------------	--------------------	---------------------------	---

Description

Service enumeration identified a legacy Linux and web application stack. Observable components included Apache 2.2.14, PHP 5.3.2, OpenSSL 0.9.8k, OpenSSH 5.3p1, Python 2.6.5, Perl 5.10.1, Jetty 6.1.25, an older Tomcat/Coyote engine, and a Linux 2.6.32 kernel. Nikto independently reported multiple components as outdated.

```
root@kali:~# whatweb -a 3 http://192.168.68.12 | tee /root/it460-final/scans/whatweb-owaspbwa.txt
http://192.168.68.12 [200 OK] Apache[2.2.14][mod_mono/2.4.3,mod_perl/2.0.4,mod_python/3.3.1,mod_ssl/2.2.14,proxy_html/3.0.1], Country[RESERVED][ZZ], Email[admin@metacorp.com,admin@owaspbwa.org,bob@ateliergraphique.com,cycloneuser-3@cyclonetransfers.com,jack@metacorp.com,test@thebodgeitstore.com], HTML5, HTTPServer[Ubuntu Linux][Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1], IP[192.168.68.12], JQuery[1.3.2], OpenSSL[0.9.8k], PHP[5.3.2-1ubuntu4.30][Suhosin-Patch], Passenger[4.0.38], Perl[5.10.1], Python[2.6.5], Script[text/javascript], Title[owaspbwa OWASP Broken Web Applications]
```

Figure F-04.1 — WhatWeb fingerprinted the legacy Apache, PHP, OpenSSL, Python, Perl, and Passenger stack.

Impact

Unsupported components accumulate publicly known vulnerabilities and may no longer receive security fixes. Exact exploitability depends on build options and configuration, but the breadth and age of the observed stack materially increase the likelihood of remote compromise and make safe maintenance impractical.

Recommended remediation

Priority	Action
1	Rebuild the host on a supported operating system and supported web/application runtimes rather than patching the legacy image in place.
2	Maintain a component inventory or SBOM with ownership, version, support status, and patch deadlines.
3	Remove unused runtimes, modules, and listeners to reduce the attack surface.
4	Establish recurring authenticated vulnerability scans and patch compliance reporting.

04 / DETAILED FINDINGS

F-05 Web Server Security Misconfiguration

SEVERITY Medium	CVSS 6.5	STATUS Observed	ASSET OWASP BWA / 192.168.68.12
---------------------------	--------------------	---------------------------	---

Description

The web tier exposed multiple defense-in-depth weaknesses. Nikto and Nmap reported TRACE enabled, directory indexing, an exposed phpMyAdmin path, cookies without HttpOnly, a permissive crossdomain.xml policy, missing browser security headers, and internal address information in a Location response. These issues increase information leakage and make exploitation of other weaknesses easier.

```
root@kali:~# nikto -h http://192.168.68.12 -output /root/it460-final/scans/nikto-owaspbwa.txt
- Nikto v2.1.6
-----
+ Target IP:      192.168.68.12
+ Target Hostname: 192.168.68.12
+ Target Port:    80
+ Start Time:    2026-08-23 17:24:53 (GMT-4)
-----
+ Server: Apache/2.2.14 (Ubuntu) mod_mono/2.4.3 PHP/5.3.2-1ubuntu4.30 with Suhosin-Patch proxy_html/3.0.1 mod
_python/3.3.1 Python/2.6.5 mod_ssl/2.2.14 OpenSSL/0.9.8k Phusion_Passenger/4.0.38 mod_perl/2.0.4 Perl/v5.10.1
+ Server may leak inodes via ETags, header found with file /, inode: 286483, size: 28067, mtime: Thu Jul 30 2
2:55:52 2015
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some
forms of XSS
+ The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the
site in a different fashion to the MIME type
+ OSVDB-3268: /cgi-bin/: Directory indexing found.
+ /crossdomain.xml contains a full wildcard entry. See http://jeremiahgrossman.blogspot.com/2008/05/crossdoma
inxml-invites-cross-site.html
```

Figure F-05.1 — Nikto evidence for missing headers, directory indexing, permissive policy, and exposed server metadata.

Impact

Individually, these settings may not provide direct compromise. In combination they improve attacker reconnaissance, expose sensitive administration interfaces, weaken session protection, and increase the impact of browser-side flaws such as clickjacking and content-type confusion.

Recommended remediation

Priority	Action
1	Disable TRACE and all HTTP methods not required by the application.
2	Disable directory listings and remove sample, test, icon, and documentation directories from production.
3	Restrict phpMyAdmin to trusted management hosts or remove it from the web tier.
4	Set Secure, HttpOnly, and SameSite attributes on session cookies and deploy a restrictive Content-Security-Policy.
5	Add X-Content-Type-Options: nosniff and CSP frame-ancestors; eliminate wildcard cross-domain policy entries.

04 / DETAILED FINDINGS

F-06 Verbose Error and Internal Path Disclosure

SEVERITY Medium	CVSS 5.3	STATUS Validated	ASSET OWASP BWA / 192.168.68.12
--------------------	-------------	---------------------	---------------------------------------

Description

A malformed SQL injection attempt triggered a detailed application exception. The response exposed the local path to MySQLHandler.php, source line numbers, MySQL error 1064, client version 5.1.73, local UNIX-socket usage, the generated query, and a multi-frame stack trace.

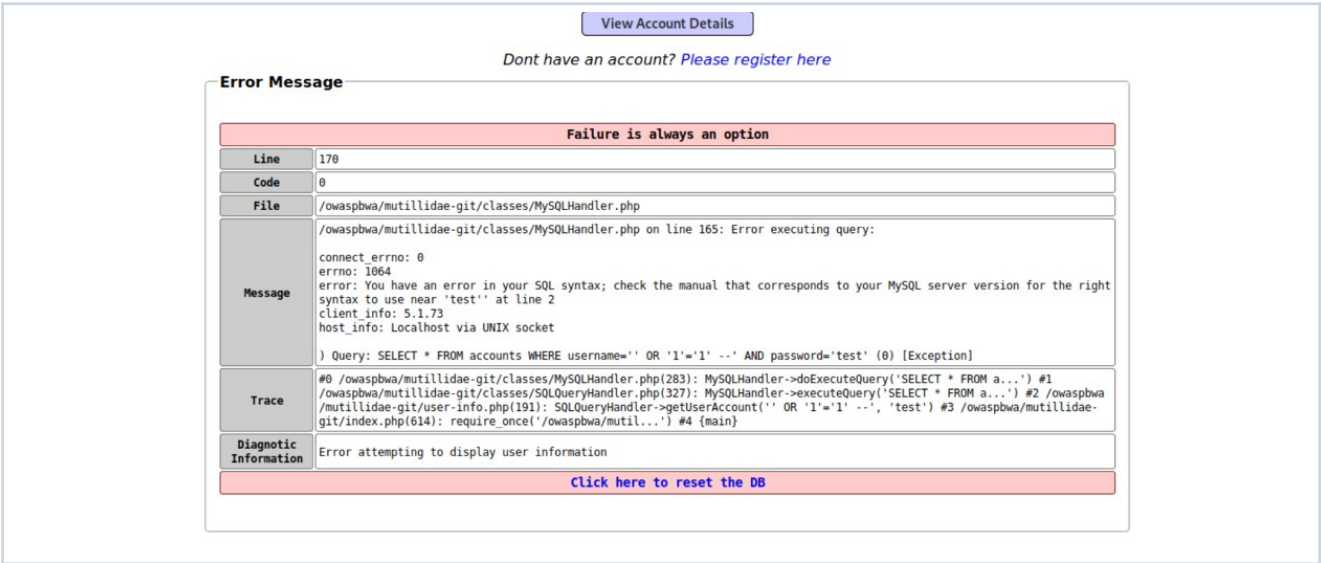


Figure F-06.1 — The application disclosed internal paths, query text, database details, and stack trace data.

Impact

Verbose errors help attackers understand query structure, application layout, libraries, and database behavior. This information reduces the time required to refine injection payloads and identify additional attack paths.

Recommended remediation

Priority	Action
1	Return generic error messages to clients and record diagnostic detail only in protected server-side logs.
2	Disable debug and stack-trace output in production configurations.
3	Use centralized logging with access control, retention, correlation identifiers, and alerting.
4	Review all exception handlers to prevent disclosure of paths, queries, connection details, and library versions.

04 / DETAILED FINDINGS

F-07 SMB Message Signing Disabled

SEVERITY Medium	CVSS 5.9	STATUS Observed	ASSET OWASP BWA / 192.168.68.12
---------------------------	--------------------	---------------------------	---

Description

Ports 139 and 445 exposed Samba services. The Nmap smb-security-mode script reported user-level authentication, guest account use, challenge-response support, and message signing disabled. SMB2 negotiation failed, suggesting reliance on older protocol behavior.

```
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.32
OS details: Linux 2.6.32
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: OWASPBWA, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/s
ubmit/ .
Nmap done: 1 IP address (1 host up) scanned in 123.63 seconds
```

Figure F-07.1 — Nmap reported SMB message signing disabled and failed SMB2 negotiation.

Impact

Unsigned SMB traffic can be modified or relayed by an attacker with an appropriate network position. Legacy protocol support and guest access further increase exposure. The assessment did not perform credential relay or destructive SMB testing.

Recommended remediation

Priority	Action
1	Require SMB signing on both clients and servers and verify enforcement through policy and testing.
2	Disable SMB1 and other legacy dialects; update Samba to a supported release.
3	Disable guest access unless there is a documented business requirement.
4	Restrict ports 139 and 445 to explicitly authorized segments and block them at external boundaries.

05 / ACTION PLAN

Remediation Roadmap

Priority	Target window	Action	Validation evidence
P0	0-24 hours	Isolate the application; block untrusted access; rotate exposed credentials.	Access control test and credential invalidation record
P0	0-72 hours	Correct SQL and command injection; remove unauthenticated setup/reset access.	Peer-reviewed code change and negative retest
P1	7 days	Rebuild on supported OS, web server, runtime, crypto, and application components.	New inventory, authenticated scan, and patch report
P1	14 days	Harden HTTP, cookies, errors, phpMyAdmin exposure, directory listings, and allowed methods.	Header/path review and repeat Nikto/Nmap results
P2	30 days	Require SMB signing, remove legacy dialects/guest access, and restrict network reachability.	Policy export and SMB security-mode retest
P2	Ongoing	Add secure coding gates, dependency tracking, logging, alerting, and quarterly validation.	CI evidence, SBOM, alert test, and recurring assessment record

Retest acceptance criteria

- Injection payloads are rejected or treated as data; no database rows or command output are exposed.
- No setup, reset, or administrative function is available without authenticated authorization.
- All externally reachable components are supported, inventoried, and patched to approved baselines.
- TRACE, directory listing, verbose errors, and unneeded management paths are unavailable.
- SMB signing is required, guest access is disabled, and legacy dialect negotiation fails closed.

06 / CLOSEOUT

Conclusion

The assessment met its objective by identifying the reachable services on the OWASP BWA target, fingerprinting the application stack, validating two critical injection flaws, documenting additional material weaknesses, and producing a prioritized remediation plan. The most important result is not the number of findings; it is the demonstrated ability to move from ordinary HTTP access to credential disclosure, administrative login, and server-side command execution.

The environment should be considered unsafe for any real data or production use. If this were a live system, immediate containment and a supported-platform rebuild would be more reliable than piecemeal remediation of the legacy stack. After corrective work, an independent retest should verify each acceptance criterion and confirm that compensating controls do not merely hide the vulnerable code paths.

Professional reflection

This project reinforced the importance of treating automated scan output as a starting point rather than a finished assessment. Nmap, WhatWeb, and Nikto established the attack surface, but the strongest evidence came from controlled manual validation: the SQL injection returned real records, the disclosed credential authenticated successfully, and command injection returned the web service identity. The work also showed why scope discipline matters. The network contained additional systems, but the report remained focused on the authorized DMZ target and avoided disruptive techniques. Finally, capturing concise evidence throughout the engagement made it possible to connect each technical observation to a reproducible proof, a concrete impact statement, and a practical remediation.

Final assessment The OWASP BWA target presents CRITICAL risk by design. The validated paths are fully reproducible within the assigned lab and directly support the remediation priorities in this report.

APPENDIX A

Observed Services

Port	Service	Observed detail
22/tcp	SSH	OpenSSH 5.3p1 Debian 3ubuntu4
80/tcp	HTTP	Apache httpd 2.2.14; PHP 5.3.2; TRACE enabled
139/tcp	NetBIOS/SMB	Samba smbd 3.X-4.X
143/tcp	IMAP	Courier Imapd (released 2008)
443/tcp	HTTPS	TLS-enabled web service; exact product uncertain
445/tcp	SMB	Samba smbd 3.X-4.X; signing disabled
5001/tcp	Java object service	Java Object Serialization
8080/tcp	HTTP	Apache Tomcat/Coyote JSP engine 1.1
8081/tcp	HTTP	Jetty 6.1.25; TRACE enabled

Note: Service identification is based on Nmap responses and banners. Where the response was ambiguous, the description remains qualified rather than asserting a definitive product.

APPENDIX B

Reproduction and Evidence Index

Purpose	Command or input
Network context	ip -br addr ip route
Full TCP scan	nmap -Pn -p- -T4 --min-rate 1000 --reason 192.168.68.12 -oA /root/it460-final/scans/owaspbwa-full
Service enumeration	nmap -Pn -sC -sV -O --version-all 192.168.68.12 -oA /root/it460-final/scans/owaspbwa-services
Web fingerprint	whatweb -a 3 http://192.168.68.12 tee /root/it460-final/scans/whatweb-owaspbwa.txt
Web scan	nikto -h http://192.168.68.12 -output /root/it460-final/scans/nikto-owaspbwa.txt
SQL injection	Mutillidae User Info: Name = ' OR 1=1 # ; Password = test
Command injection	Mutillidae DNS Lookup: 127.0.0.1 && whoami && id

Evidence handling notes

- Nmap output was saved in normal, XML, and grepable formats using -oA.
- A terminal transcript was started before testing to preserve command context.
- Screenshots were captured immediately after deterministic results appeared.
- Dates displayed by lab systems reflect the configured cyber-range clock.

APPENDIX C**References**

1. [OWASP Mutillidae II Project](#)
2. [Damn Vulnerable Web Application \(DVWA\)](#)
3. [OWASP SQL Injection Prevention Cheat Sheet](#)
4. [OWASP OS Command Injection Defense Cheat Sheet](#)
5. [OWASP Password Storage Cheat Sheet](#)
6. [OWASP Error Handling Cheat Sheet](#)
7. [OWASP HTTP Headers Cheat Sheet](#)
8. [OWASP Top 10: Vulnerable and Outdated Components](#)
9. [Nmap Reference Guide](#)
10. [Microsoft SMB Signing Overview](#)

Source materials

IT460 Final Project instructions (course-provided DOCX); NDG Ethical Hacking v2 Cyber Range guide (course-provided PDF); and assessment evidence captured from the assigned NetLab environment on August 23, 2026.